Access Management Policy
Version 1.1

TABLE OF CONTENTS

1. Document Control.....1
1.1. Version Control.....2
1.2. Approval Matrix.....3
2. Introduction.....4
2.1. Purpose.....4
2.2. Scope.....4
3. Policy Principles.....4
4. Policy Statements.....4
5. Governance.....7
5.1. Compliance.....7
5.2. Exceptions.....7
5.3. Review and Update.....7
5.4. Roles & Responsibilities.....7

1. Document Control

Version	Date Published	Author	Reason for change
1.0	21-09-2025	Daniel Anagu	Peer-review comments
1.1	10-10-2025	Daniel Anagu	

1.2. Approval Matrix

Version	Approval Full Name	Approver Title	Approval Date
1.1	XXXX	VP, Cybersecurity	15-10-2025

2. Introduction

2.1. Purpose

The 'Access Management Policy' (this policy) document defines how access to company resources is controlled in line with cybersecurity risk and compliance requirements.

2.2. Scope

This policy is applicable to all departments and users of the company and includes all resources and assets owned and/or managed by the company.

This policy also applies to any and all external parties that have access to the company resources and assets irrespective of their legal employer.

3. Policy Principles

- **Authentication** - Validate the authenticity of the user attempting to gain access to the resources and assets.
- **Authorisation** - Ensure access to a particular resource or asset is restricted to actions needed for a particular business function, and is not excessive in nature.
- **Accounting** - Ensure that there is visibility on who is doing what once access is granted to a given resource, and that such information is available for investigation upon request.
- **Privacy** - Ensure that access mechanisms are designed and deployed to ensure privacy of data accessible from a particular system resource or asset

4. Policy statements

General

1. All accounts/ user identity (ID) must be uniquely identifiable to ensure the account owner must be clearly identifiable
2. Where an account/user ID is not uniquely identifiable, a named account owner must be assigned by the management to ensure accountability.
3. Access to any resources and/or assets must be restricted on a 'need-to-know' basis only, typically driven by the job role.
4. Defined procedures must be established to ensure clarity over the various accounts/user IDs level activities, e.g., create, enable, modify, disable, and/or remove in accordance with approved procedures.
5. The use of accounts/user ID must be monitored to ensure any unauthorised activity can be detected and responded to.
6. Deactivate accounts when no longer required, e.g., when users are terminated or their role changes.
7. Review accounts for compliance with regulatory requirements.
8. Ensure that the systems automatically disable inactive accounts after a pre-defined frequency of inactivity.
9. Ensure that the systems automatically audit account creation, modification, enabling, disabling, and removal actions, and notify appropriate personnel.
10. Ensure that the system enforce approved authorisations for logical access to information and system resources in accordance with the user role.

11. Access to resources and assets must consider separation of duties of individuals as necessary, to reduce the chances of malicious activity due to collusion.
12. Employ the principle of least privilege, allowing only authorised access for users (or processes acting on behalf of users) which are necessary to accomplish assigned tasks in accordance with organisational missions and business functions.
13. Restrict access to privileged accounts on the information system to identified roles only, and ensure that non-privileged users must not be able to execute privileged functions to circumvent implemented security safeguards/countermeasures.
14. Where possible, enable time-constrained access to privileged accounts. a. Ensure that execution of privileged functions is audited and monitored on a regular basis.
15. Enforce a limit of consecutive invalid login attempts by a user during a given period of time, and ensure that the accounts/User IDs are automatically locked when such limit is exceeded.
16. Ensure that the information system automatically terminates a user session after a given period of inactivity.

Remote Access

1. Establish and document usage restrictions, configuration/connection requirements, and implementation guidance for each type of remote access allowed.
2. Authorize remote access to the information system prior to allowing such connections.
3. Ensure that the information system monitors and controls remote access methods.
4. Ensure that the information system implements cryptographic mechanisms to protect the confidentiality and integrity of remote access sessions.
5. Ensure that the information system routes all remote accesses through managed network access control points to reduce the risk of external attacks.

Wireless Access

1. Wireless Access Establish usage restrictions, configuration/connection requirements, and implementation guidance for wireless access.
2. Authorise wireless access to the information system prior to allowing such connections.
3. Ensure that the information system protects wireless access to the system using authentication of users and devices and encryption.

Access Control for Mobile Devices

1. Establish usage restrictions, configuration requirements, connection requirements, and implementation guidance for organisation-controlled mobile devices.

2. Authorise the connection of mobile devices to organisational information systems
3. Employ full-device encryption or container encryption to protect the confidentiality and integrity of information on approved devices.
4. Enable mechanism to manage, monitor and control access to organisational information from personal mobile devices.

Access to External Information Systems

1. Establish terms and conditions, consistent with any trust relationships established with other organisations owning, operating, and/or maintaining external information systems, allowing authorised individuals to:

a. Access the information system from external information systems.
b. Process, store, or transmit organisation-controlled information using external information systems.

2. Permit authorised individuals to use an external information system to access the organisation's information system or to process, store, or transmit organisation-controlled information only when the organisation:
    a. Verifies the implementation of required security controls on the external system as specified in the organisation's information security policy and security plan.

    b. Retains approved information system connection or processing agreements with the organisational entity hosting the external information system.

5. Governance

5.1. Compliance

Compliance with this policy is mandatory for all users with access to organisational resources and assets.

Non-compliance with this policy may result in disciplinary action, including but not limited to, access suspension, termination of employment, or legal consequences.

5.2. Exceptions

Any questions, issues, or exceptions related to the use of this policy should be raised with the Cybersecurity team.

5.3. Review and Update

This policy will be reviewed at a minimum on an annual basis or at the time of any significant changes to company operations or developments in the technological ecosystem.

5.4. Roles & Responsibilities

- All employees must be aware of their responsibilities for protecting confidential and sensitive information and must take all necessary steps to safeguard the privacy of organisational information and assets.
- Managers and supervisors are responsible for ensuring that their teams are aware of and comply with this policy. They must report any violations of this policy, for example those relating to contractors and service providers immediately to leadership.

END OF DOCUMENT

RACI MATRIX

Expectation	**Responsible Party**	**Accountable Party**	**Consulted Party**	**Informed Party**
Ensuring that their teams are aware of and comply with this policy	**Supervisor/Team lead**	**Manager**	**Cybersecurity team**	**All employees**
Protecting confidential and sensitive information	**All employees**	**Supervisor/ Team Lead**	**Cybersecurity team**	**Manager**